

Information Security Policy

Company: Cashpile
Effective Date: April 26, 2026
Version: 1.0
Owner: Security Team

1. Purpose and Scope

This Information Security Policy establishes the framework for protecting Cashpile's information assets, including customer financial data accessed through Plaid's services. This policy applies to all employees, contractors, and third parties with access to Cashpile systems and data.

2. Information Security Objectives

- Protect customer financial data confidentiality, integrity, and availability
- Comply with applicable laws, regulations, and industry standards
- Prevent unauthorized access to sensitive information
- Ensure business continuity and disaster recovery
- Maintain customer trust and regulatory compliance

3. Data Classification and Handling

3.1 Data Classification

Classification	Description	Examples
Critical	Highly sensitive financial data requiring maximum protection	Bank account numbers, transaction history, access tokens
Confidential	Business-sensitive information	Customer PII, API credentials, internal reports
Internal	Company-internal information	Internal documentation, non-production code
Public	Information approved for public release	Marketing materials, public website content

3.2 Data Handling Requirements

- **Critical data:** Encrypted at rest (AES-256) and in transit (TLS 1.3)
- **Access tokens:** Stored encrypted, never logged, rotated on suspicion of compromise
- **Financial data:** Accessed only via authenticated, authorized APIs with audit logging

4. Access Control

4.1 Authentication

- Multi-factor authentication (MFA) required for all production system access
- Single Sign-On (SSO) enforced where available
- Strong password policies (minimum 16 characters, complexity requirements)
- Session timeouts after 15 minutes of inactivity

4.2 Authorization

- Principle of least privilege: Users receive minimum necessary access
- Role-based access control (RBAC) enforced
- Quarterly access reviews for all privileged accounts
- Immediate revocation upon termination or role change

4.3 Plaid-Specific Access Controls

- Plaid access tokens stored encrypted in Supabase with RLS policies
- Tokens never exposed to client-side code
- Webhook endpoints verify authenticity (planned for production)
- Access limited to service-role operations only

5. Data Protection

5.1 Encryption

Layer	Method
Data at rest	AES-256 (Supabase-managed)
Data in transit	TLS 1.3
Database connections	SSL/TLS enforced
API communications	HTTPS only

5.2 Key Management

- Encryption keys managed by Supabase (managed service)
- Environment secrets stored in secure environment variables
- No hardcoded credentials in source code
- Secrets rotated quarterly

5.3 Data Retention and Disposal

- Customer data retained only as long as legally required or necessary for service
- Secure deletion procedures for data disposal
- Backup retention: 30 days with encrypted storage

6. Application Security

6.1 Secure Development

- Security reviews required for all code changes

- Dependency scanning for known vulnerabilities
- Static Application Security Testing (SAST) in CI/CD pipeline
- No production secrets in version control

6.2 API Security

- Rate limiting enforced on all public endpoints
- Input validation and sanitization
- Output encoding to prevent injection attacks
- Authentication required for all sensitive operations

6.3 Third-Party Security (Plaid Integration)

- Plaid SDK used for all financial data access
- Sandbox environment used for development/testing
- Production credentials restricted to production environment only
- Webhook signature verification implemented (production)

7. Network Security

- Web Application Firewall (WAF) protection
- DDoS mitigation via hosting provider (Railway)
- Network segmentation between environments
- Regular vulnerability scanning

8. Incident Response

8.1 Incident Classification

Severity	Definition	Response Time
Critical	Data breach, unauthorized financial access	1 hour
High	System compromise, token exposure	4 hours
Medium	Policy violation, suspicious activity	24 hours
Low	Minor policy infraction	72 hours

8.2 Response Procedures

1. **Detection:** Automated monitoring alerts and manual reporting
2. **Containment:** Immediate isolation of affected systems
3. **Investigation:** Root cause analysis and impact assessment
4. **Remediation:** Fix vulnerabilities and restore services
5. **Communication:** Notify affected parties per legal requirements
6. **Post-Incident:** Review and update security measures

8.3 Plaid-Specific Incident Handling

- Immediate token revocation if Plaid credentials compromised

- Notification to Plaid within 24 hours of security incident
- Audit log review for unauthorized Plaid API access

9. Business Continuity and Disaster Recovery

- Daily automated backups of critical data
- Recovery Time Objective (RTO): 4 hours
- Recovery Point Objective (RPO): 24 hours
- Annual disaster recovery testing

10. Compliance and Auditing

10.1 Regulatory Compliance

- SOC 2 Type II compliance (planned)
- GDPR compliance for EU customers
- CCPA compliance for California residents
- PCI DSS considerations for payment data

10.2 Audit Logging

- All access to financial data logged
- Log retention: 1 year
- Immutable logs for security events
- Regular log review for anomalies

10.3 Plaid Compliance

- Annual security policy review
- Employee security training
- Secure handling of Plaid access tokens per Plaid's requirements

11. Employee Responsibilities

- Complete annual security awareness training
- Report security incidents immediately
- Follow secure password practices
- Lock devices when unattended
- Never share credentials

12. Third-Party Management

- Security assessments for all vendors with data access
- Data Processing Agreements (DPA) in place
- Regular vendor security reviews
- **Key vendors:**
 - Supabase (database hosting)
 - Railway (application hosting)
 - Plaid (financial data aggregation)

13. Policy Review

This policy is reviewed annually or upon significant changes to:

- Business operations
- Regulatory requirements
- Technology stack
- Threat landscape

Last Review: April 26, 2026

Next Review: April 26, 2027

14. Contact Information

Security Inquiries: security@cashpile.app

Incident Reporting: security@cashpile.app

This document is confidential and intended for internal use and regulatory compliance purposes only.